



Challenge Profile

- **Platform:** HackTheBox
- **Track:** Sherlocks (Defensive Security / Blue Team)
- **Category:** DFIR (Digital Forensics and Incident Response)
- **Difficulty Level:** Very Easy
- **Sherlock Scenario:** An APT group is using Hajj-themed phishing lures to target and steal WhatsApp data from government and diplomatic officials. Our team has gathered fragmented intelligence from public cybersecurity vendor reports, blog posts, and internal security alerts. Your task is to build a comprehensive profile of the threat actor responsible. You must connect the dots between different reports to answer questions about their identity, tools, and motives.

Below are the sites we have compiled, use these to answer the following questions. (If any of the sites become unavailable please check on wayback machine as they all have been saved).

Evidence - 1 - <https://securelist.com/mysterious-elephant-apt-ttps-and-tools/117596/>
Evidence - 2 - <https://medium.com/@knownsec404team/apt-k-47-mysterious-elephant-a-new-apt-organization-in-south-asia-5c66f954477> Evidence - 3 -
<https://medium.com/@knownsec404team/unveiling-the-past-and-present-of-apt-k-47-weapon-asyncshell-5a98f75c2d68>

Solving

Task 1

- **Question:** What is the primary name of the APT group described in the SecureList report?
- **Analysis:**
 - Access the link Evidence - 1 and collect the information

// AUTHORS



NOUSHIN SHABAB



Expert YE JIN

Introduction

Mysterious Elephant is a highly active advanced persistent threat (APT) group that we at Kaspersky GReAT discovered in 2023. It has been consistently evolving and adapting its tactics, techniques, and procedures (TTPs) to stay under the radar. With a primary focus on targeting government entities and foreign affairs sectors in the Asia-Pacific region, the group has been using a range of sophisticated tools and techniques to infiltrate and exfiltrate sensitive information. Notably, Mysterious Elephant has been exploiting WhatsApp communications to steal sensitive data, including documents, pictures, and archive files.

Task 1

What is the primary name of the APT group described in the SecureList report?

Mysterious Elephant



Submit Task

Task 2

- **Question:** According to the Knownsec 404 team's analysis(Evidence -3), since which year has this group's attack activity been dated back to?
- **Analysis:**
 - Access the link Evidence - 3 and collect the information

2. overview

APT-K-47, also known as Mysterious Elephant, was the first APT organization to disclose details of its activities. Knownsec 404 Advanced Threat Intelligence team [1]. The organization is presumed to have originated in the South Asian region, and its attack activities date back as far as 2022. In an in-depth analysis of APT-K-47's technical approach, tactical strategy, tool usage, and operational goals, multiple other APT organizations in South Asia can be seen, including but not limited to Sidewinder, Confucius, and Bitter.

Task 2

According to the Knownsec 404 team's analysis(Evidence -3), since which year has this group's attack activity been dated back to?

2022



Submit Task

Task 3

- **Question:** The group uses a custom backdoor that communicates via Office Remote Procedure Call (ORPCBackdoor). According to the Knownsec 404 team's analysis(Evidence -2), what is the name of the first malicious exported entry function?
- **Analysis:**
 - Access the link Evidence - 2 and collect the information

There are two malicious entries of ORPCBackdoor, the first is GetFileVersionInfoBy- HandleEx(void) export function, second place is DllEntryPoint.

Task 3

The group uses a custom backdoor that communicates via Office Remote Procedure Call (ORPCBackdoor). According to the Knownsec 404 team's analysis(Evidence -2), what is the name of the first malicious exported entry function?

GetFileVersionInfoByHandleEx(void)



Submit Task

Task 4

- **Question:** The previously mentioned backdoor checks for a file before creating persistence. What is the name of the file?
- **Analysis:**
 - Access the link: Evidence - 2 and collect the information

2. persistence

ORPCBackdoor determines whether the file exists to prevent multiple persistence. Before persistent creation, ORPCBackdoor determines whether the `ts.dat` file exists in the same path. If the file does not exist, ORPCBackdoor will create persistence. The TaskScheduler CLSID is invoked by COM, which name is Microsoft Update. After the task is created, the `ts.dat` file is created.

Task 4

The previously mentioned backdoor checks for a file before creating persistence. What is the name of the file?

`ts.dat` 

Submit Task

Task 5

- **Question:** The use of the backdoor links the APT to another well-known South Asian APT group. What is the name of this other group?
- **Analysis:**
 - Access the link Evidence-3 and Evidence - 2 and collect the information

Intelligence team [1]. The organization is presumed to have originated in the South Asian region, and its attack activities date back as far as 2022. In an in-depth analysis of APT-K-47's technical approach, tactical strategy, tool usage, and operational goals, multiple other APTs in South Asia can be seen, including but not limited to `Sidewinder, Confucius, and Bitter`.

In March 2023, we learned that the Knownsec 404 Advanced Threat Intelligence team was the first in the world to capture a new APT weapon backdoor, which we called “ORPCBackdoor”, and released a detailed analysis of the weapon backdoor in May 2023: [Bitter’s new assault weapon analysis — ORPCBackdoor weapon](#).

In the report, we identified the weapon as the latest weapon used by BITTER. However, we noticed that Kaspersky recently released a report saying that they had discovered a new APT group in the second quarter, and that the group’s main target was Pakistan. It was named the “Mysterious Elephant”.

Task 5

The use of the backdoor links the APT to another well-known South Asian APT group. What is the name of this other group?

Bitter

Submit Task

Task 6

- **Question:**The APT group we are currently investigating has consistently used and updated another backdoor since 2023, with its C2 communication evolving from TCP to HTTPS. What is the name of this tool?
- **Analysis:**
 - Access the link Evidence-3 and collect the information

Load communication changed from tcp to https, so we noted as Asyncshell-v2.

Task 6

The APT group we are currently investigating has consistently used and updated another backdoor since 2023, with its C2 communication evolving from TCP to HTTPS. What is the name of this tool?

Asyncshell-v2

Submit Task

Task 7

- **Question:** To evade sandbox analysis, the MemLoader HidenDesk tool checks the number of active processes before running. What is the minimum number of processes required for it to proceed?
- **Analysis:**
 - Access the link Evidence-1 and collect the information

Customized open-source tools

One of the latest modules used by Mysterious Elephant and loaded by BabShell is **MemLoader HidenDesk**.

MemLoader HidenDesk is a reflective PE loader that loads and executes malicious payloads in memory. It uses encryption and compression to evade detection.

MemLoader HidenDesk operates in the following manner:

- 1 The malware checks the number of active processes and terminates itself if there are fewer than 40 processes running — a technique used to evade sandbox analysis.

Task 7

To evade sandbox analysis, the MemLoader HidenDesk tool checks the number of active processes before running. What is the minimum number of processes required for it to proceed?

40 

Submit Task

Task 8

- **Question:** The MemLoader HidenDesk tool creates a covert environment for its activities by creating and switching to a specific environment. What is the name of this hidden desktop?
- **Analysis:**
 - Access the link Evidence-1 and collect the information

- 3 The malware then creates a hidden desktop named "MalwareTech_Hidden" and switches to it, providing a covert environment for its activities. This technique is borrowed from an open-source project on GitHub.

Task 8

The MemLoader HidenDesk tool creates a covert environment for its activities by creating and switching to a specific environment. What is the name of this hidden desktop?

MalwareTech_Hidden 

Submit Task

Task 9

- **Question:**The MemLoader HidenDesk tool achieves persistence by placing a shortcut in the autostart folder to ensure it runs after a system reboot. What is the MITRE ATT&CK ID for the 'Registry Run Keys / Startup Folder' technique?
- **Analysis:**
 - Search google.com

ATT&CK Matrix for Enterprise

layout: side ▾show sub-techniqueshide sub-techniques

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery
11 techniques	8 techniques	11 techniques	17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques
Active Scanning (3) Gather Victim Host Information (4) Gather Victim Identity Information (3) Gather Victim Network Information (6) Gather Victim Org Information (4) Phishing for Information (4) Search Closed Sources (2) Search Open Technical Databases (5) Search Open Websites/Domains (3) Search Threat Vendor Data	Acquire Access Acquire Infrastructure (8) Compromise Accounts (3) Compromise Infrastructure (8) Develop Capabilities (4) Establish Accounts (3) Obtain Capabilities (7) Stage Capabilities (6)	Content Injection Drive-by Compromise Exploit Public-Facing Application External Remote Services Hardware Additions Phishing (4) Replication Through Removable Media Supply Chain Compromise (3) Trusted Relationship Valid Accounts (4)	Cloud Administration Command Command and Scripting Interpreter (13) Container Administration Command Deploy Container ESXi Administration Command Exploitation for Client Execution Input Injection Inter-Process Communication (3) Native API Poisoned Pipeline Execution Scheduled Task/Job	Account Manipulation (7) BITS Jobs Registry Run Keys / Startup Folder Authentication Package Time Providers Winlogon Helper DLL Security Support Provider Kernel Modules and Extensions Re-opened Applications LSASS Driver Shortcut Modification Port Monitors Print Processors XDG Autostart Entries Active Setup Login Items	Abuse Elevation Control Mechanism (6) Access Token Manipulation (5) Account Manipulation (7) Boot or Logon Autostart Execution (14) Boot or Logon Initialization Scripts (5) Create or Modify System Process (5) Domain or Tenant Policy Modification (2) Escape to Host Event Triggered Execution (18) Exploitation for	Abuse Elevation Control Mechanism (6) Access Token Manipulation (5) BITS Jobs Build Image on Host Debugger Evasion Delay Execution Deobfuscate/Decode Files or Information Deploy Container Direct Volume Access Domain or Tenant Policy Modification (2) Email Spoofing Execution Guardrails (2) Exploitation for Defense Evasion File and Directory	Adversary-in-the-Middle (4) Brute Force (4) Credentials from Password Stores (6) Exploitation for Credential Access Forced Authentication Forge Web Credentials (2) Input Capture (4) Modify Authentication Process (9) Multi-Factor Authentication Interception Multi-Factor Authentication	Account Discovery (4) Application Window Discovery Browser Information Discovery Cloud Infrastructure Discovery Cloud Service Dashboard Cloud Service Discovery Cloud Storage Object Discovery Container and Resource Discovery Debugger Evasion Device Driver Discovery Domain Trust Discovery File and Directory Discovery

https://attack.mitre.org/techniques/T1547/001

Task 9

The MemLoader HidenDesk tool achieves persistence by placing a shortcut in the autostart folder to ensure it runs after a system reboot. What is the MITRE ATT&CK ID for the 'Registry Run Keys / Startup Folder' technique?

T1547.001

Submit Task

Task 10

- **Question:**The actor uses several custom exfiltration tools targeting WhatsApp. What is the name of the tool that recursively searches specific directories, including the "Desktop" and "Downloads" folders?
- **Analysis:**
 - Access the link Evidence-1 and collect the information

Stom Exfiltrator

The Stom Exfiltrator is a commonly used exfiltration tool that recursively searches specific directories, including the "Desktop" and "Downloads" folders, as well as all drives except the C drive, to collect files with predefined extensions. Its latest variant is specifically designed to target files shared through the WhatsApp application. This version uses a hardcoded folder path to locate and exfiltrate such files:

Task 10

The actor uses several custom exfiltration tools targeting WhatsApp. What is the name of the tool that recursively searches specific directories, including the "Desktop" and "Downloads" folders?

Stom Exfiltrator

Submit Task

Task 11

- Question:** Kaspersky's analysis highlights the actor's heavy use of scripts for execution and deploying payloads. What is the MITRE ATT&CK ID for the 'PowerShell' technique?
- Analysis:**
 - Search google.com

ATT&CK Matrix for Enterprise										
		layout: side ▾		show sub-techniques		hide sub-techniques				
Category	Resource Development 8 techniques	Initial Access 11 techniques	Execution 17 techniques	Persistence 23 techniques	Privilege Escalation 14 techniques	Defense Evasion 47 techniques	Credential Access 17 techniques	Discovery 34 techniques	Lateral Movement 9 techniques	Collection 17 techniques
Initial Access	Acquire Access Acquire Infrastructure (8) Compromise Accounts (3) Compromise Infrastructure (8) Develop Capabilities (4) Establish Accounts (3) Obtain Capabilities (7) Stage Capabilities (6)	Content Injection Drive-by Compromise Exploit Public-Facing Application External Remote Services Hardware Additions Phishing (4) Replication Through Removable Media Supply Chain Compromise (3) Trusted Relationship Valid Accounts (4) Wi-Fi Networks	Cloud Administration Command PowerShell AppleScript Windows Command Shell Unix Shell Visual Basic Python JavaScript Network Device CLI Cloud API AutoHotKey & AutoIT Lua Hypervisor CLI Container CLI/API	Account Manipulation (7) BITS Jobs Boot or Logon Autostart Execution (14) Boot or Logon Initialization Scripts (5) Cloud Application Integration Compromise Host Software Binary Create Account (3) Create or Modify System Process (5) Create or Modify System Process (5) Event Triggered Execution (18) Exclusive Control External Remote Services	Abuse Elevation Control Mechanism (6) Access Token Manipulation (5) Account Manipulation (7) Boot or Logon Autostart Execution (14) Boot or Logon Initialization Scripts (5) Create or Modify System Process (5) Domain or Tenant Policy Modification (2) Escape to Host Event Triggered Execution (18) Exploitation for Privilege Escalation Hijack Execution	Abuse Elevation Control Mechanism (6) Access Token Manipulation (5) BITS Jobs Build Image on Host Debugger Evasion Delay Execution Deobfuscate/Decode Files or Information Deploy Container Direct Volume Access Domain or Tenant Policy Modification (2) Email Spoofing Execution Guardrails (2) Exploitation for Defense Evasion File and Directory Permissions Modification (2) Hide Artifacts (14)	Adversary-in-the-Middle (4) Brute Force (4) Credentials from Password Stores (6) Exploitation for Credential Access Forced Authentication Forge Web Credentials (2) Input Capture (4) Modify Authentication Process (9) Multi-Factor Authentication Interception Multi-Factor Authentication Request Generation Network Sniffing	Account Discovery (4) Application Window Discovery Browser Information Discovery Cloud Infrastructure Discovery Cloud Service Dashboard Cloud Service Discovery Cloud Storage Object Discovery Container and Resource Discovery Debugger Evasion Device Driver Discovery Domain Trust Discovery File and Directory Discovery Group Policy Discovery Local Storage	Exploitation of Remote Services Internal Spearphishing Lateral Tool Transfer Remote Service Session Hijacking (2) Remote Services (8) Replication Through Removable Media Software Deployment Tools Taint Shared Content Use Alternate Authentication Material (4)	Adversary-in-the-Middle Archive Collection Data (3) Audio Capture Automated Collection Browser Session Hijacking Clipboard Data from Cloud Storage Data from Configuration Repository Data from Information Repository Data from Local Storage Data from Network Shared Storage Data from Remote Storage

Task 11

Kaspersky's analysis highlights the actor's heavy use of scripts for execution and deploying payloads. What is the MITRE ATT&CK ID for the 'PowerShell' technique?

T1059.001

Submit Task

Task 12

- Question:** In their early attack chains, Mysterious Elephant used a downloader that was previously associated with the Origami Elephant group. What was the name of this downloader?
- Analysis:**
 - Access the link Evidence-1 and collect the information

code into their own operations and creating new, advanced versions. The actor's early attack chains featured distinctive elements, such as remote template injections and exploitation of [CVE-2017-11882](#), followed by the use of a downloader called "Vtyrei", which was previously connected to

Task 12

In their early attack chains, Mysterious Elephant used a downloader that was previously associated with the Origami Elephant group. What was the name of this downloader?

Vtyrei

Submit Task

Task 13

- **Question:**In a January 2024 campaign delivering an Asyncshell payload, which CVE was exploited in the malicious archive file?
- **Analysis:**
 - Access the link Evidence-3 and collect the information

4.1 Discover Asyncshell for the first time

Our team first discovered Asyncshell back in January 2024, when we found a malicious sample exploiting the CVE-2023-38831 vulnerability, with the overall attack chain shown below:

Task 13

In a January 2024 campaign delivering an Asyncshell payload, which CVE was exploited in the malicious archive file?

CVE-2023-38831

Submit Task

Task 14

- **Question:**What is the MD5 hash of the ChromeStealer Exfiltrator sample named WhatsAppOB.exe?
- **Analysis:**
 - Access the link Evidence-1 and collect the information

ChromeStealer Exfiltrator

[9e50adb6107067ff0bab73307f5499b6](#) WhatsAppOB.exe

Task 14

What is the MD5 hash of the ChromeStealer Exfiltrator sample named WhatsAppOB.exe?

9e50adb6107067ff0bab73307f5499b6

Submit Task

Task 15

- Question:**The intelligence describes multiple custom tools designed to upload stolen data to the actor's servers. According to the MITRE ATT&CK framework, what is the ID for the 'Exfiltration Over C2 Channel' technique?
- Analysis:**
 - Search google.com 😊)

MITRE ATT&CK®											
Matrices ▾ Tactics ▾ Techniques ▾ Defenses ▾ CTI ▾ Resources ▾ Benefactors Contribute Blog 🔗 Search 🔍											
layout: side ▾ show sub-techniques hide sub-techniques											
Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact	
17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques	
Cloud Administration Command	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Abuse Elevation Control Mechanism (6)	Adversary-in-the-Middle (4)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (4)	Application Layer Protocol (5)	Automated Exfiltration (1)	Account Access Removal	
Command and Scripting Interpreter (13)	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction (1)	
Container Administration Command	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	Build Image on Host	Credentials from Password Stores (6)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over A P T1041	Data Encrypted for Impact	
Deploy Container	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	Debugger Evasion	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Automated Collection	Data Encoding (2)	Exfiltration Over C2 Channel	Data Manipulation (3)	
ESXi Administration Command	Cloud Application Integration	Boot or Logon Initialization Scripts (5)	Deobfuscate/Decode Files or Information	Forced Authentication	Cloud Service Dashboard	Remote Services (8)	Clipboard Data	Data Obfuscation (3)	Exfiltration Over Other Network Medium (1)	Defacement (2)	
Exploitation for Client Execution	Compromise Host Software Binary	Create or Modify System Process (5)	Deploy Container	Forge Web Credentials (2)	Cloud Service Discovery	Replication Through Removable Media	Data from Cloud Storage	Dynamic Resolution (3)	Exfiltration Over Physical Medium (1)	Disk Wipe (2)	
Input Injection	Create Account (3)	Domain or Tenant Policy Modification (2)	Domain or Tenant Policy Modification (2)	Input Capture (4)	Cloud Storage Object Discovery	Software Deployment Tools	Data from Configuration Repository (2)	Encrypted Channel (2)	Exfiltration Over Web Service (4)	Email Bombing	
Inter-Process Communication (3)	Create or Modify System Process (5)	Escape to Host	Email Spoofing	Multi-Factor Authentication Process (9)	Container and Resource Discovery	Taint Shared Content	Data from Information Repositories (6)	Fallback Channels	Scheduled Transfer	Endpoint Denial of Service (4)	
Native API	Event Triggered Execution (18)	Event Triggered Execution (18)	Execution Guardrails (2)	Multi-Factor Authentication Interception	Debugger Evasion	Use Alternate Authentication Material (4)	Data from Local System	Hide Infrastructure	Transfer Data to Cloud Account	Financial Theft	
Poisoned Pipeline Execution	Exclusive Control	Exploitation for Privilege Escalation	Exploitation for Defense Evasion	Multi-Factor Authentication Request Generation	Device Driver Discovery		Data from Network Shared Drive	Ingress Tool Transfer	Resource Hijacking (4)	Firmware Corruption	
Scheduled Task/Job (5)	External Remote Services	Hijack Execution Flow (12)	File and Directory Permissions Modification (2)	Network Sniffing	Domain Trust Discovery		Non-Application Layer Protocol	Multi-Stage Channels	System Shutdown/Reboot	Inhibit System Recovery	
Serverless Execution			Hide Artifacts (14)		File and Directory Discovery					Network Denial of Service (2)	
			Hijack Execution		Group Policy Discovery					Resource Hijacking (4)	
					Local Storage Discovery					Service Stop	

Task 15

The intelligence describes multiple custom tools designed to upload stolen data to the actor's servers. According to the MITRE ATT&CK framework, what is the ID for the 'Exfiltration Over C2 Channel' technique?

T1041

Submit Task